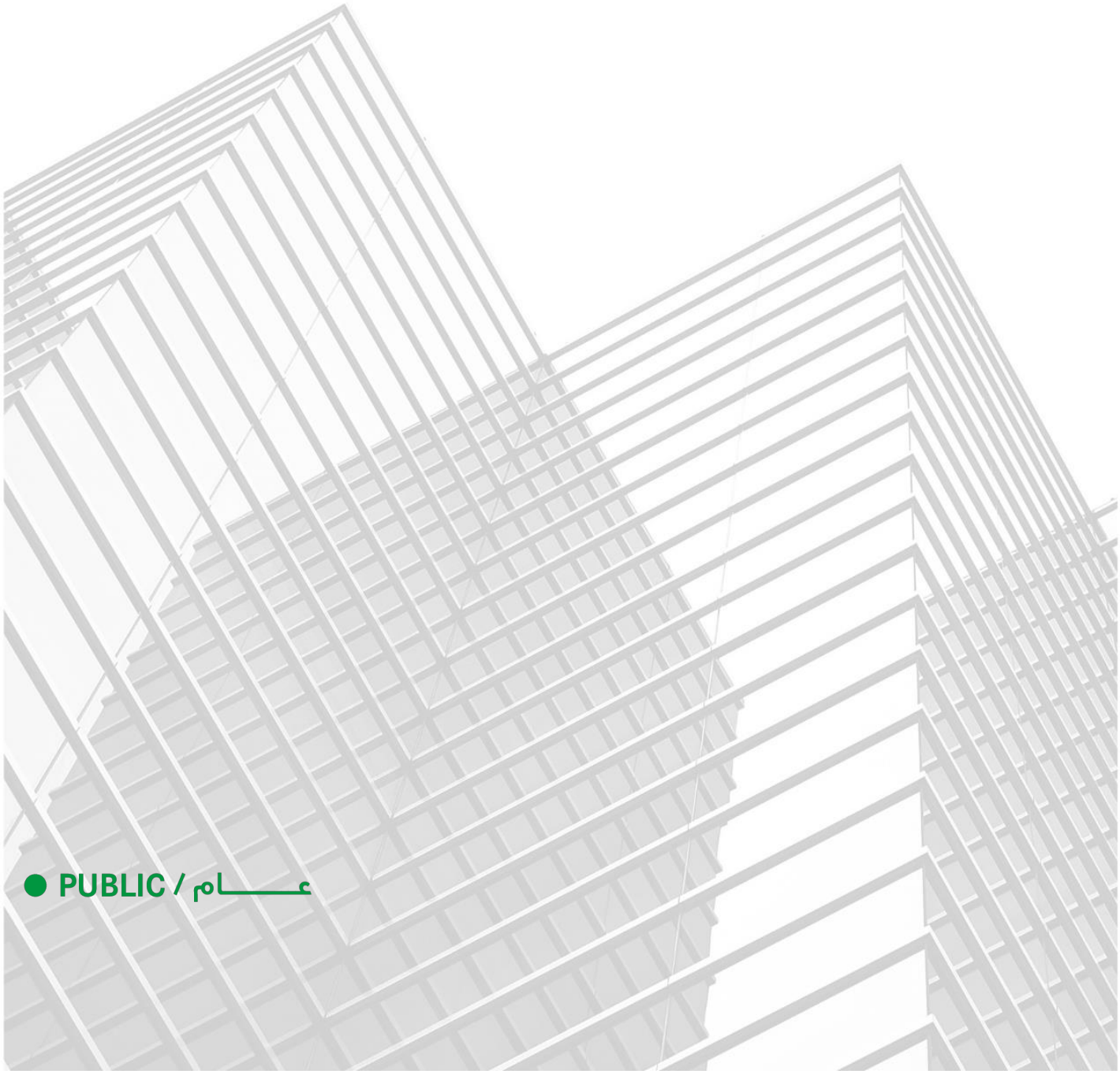
دائـــــرة الـصـــحـــة
DEPARTMENT OF HEALTH

RESPONSIBLE AI RISK MANAGEMENT PROTOCOL



● PUBLIC / عـــــــام

Document Title:	Responsible AI Risk Management Protocol		
Document Ref. Number:	DoH/Protocol/DDGO/RALRM/V1/2025	Version:	V1
New / Revised:	New		
Publication Date:	Oct 2025		
Effective Date:	Oct 2025		
Document Control:	Strategic Affairs Sector		
Applies To:	All DoH Offices, Centers, Sectors & Organization Units, Abu Dhabi Healthcare Ecosystem		
Owner:	Digital Health Sector - Data & Digital Governance Office		
Revision Date:	Oct 2028		
Revision Period:	Three years from the publication date		
Contact:	DDG@doh.gov.ae - Data & Digital Governance Office		

1.Protocol Purpose and Brief

The AI Risk Management Protocol establishes a robust framework for proactively managing risks throughout the entire lifecycle of AI applications. This includes not only the initial assessment of deployed AI use cases but also continuous monitoring of their evolution and performance. By embedding ongoing risk assessment and mitigation, the protocol ensures that AI is consistently utilized responsibly, ethically, and in full compliance with relevant regulations and guidelines, promoting data privacy, and fairness in all AI-driven healthcare initiatives.

AI Risk Management is an integral part of DoH AI Policy and DoH Responsible AI Standard.

This document is a structured approach to identifying, assessing, mitigating, and monitoring risks across the AI lifecycle. This process can be modified to optimize the process however the essence of Risk Rating and Treatment must be aligned.

2.Definitions and Abbreviations

No.	Term / Abbreviation	Definition
2.1	**Data and Digital Governance Office (DDGO)**	A centralized unit responsible for overseeing the management, security, and ethical use of data and digital assets. The DDGO drives strategies to improve data and digital governance, standardize practices, and align both with the organization's overall data and digital objectives.
2.2	**Data Governance Specialist**	A professional responsible for implementing and overseeing data governance policies, ensuring data quality, compliance, and proper management of data assets across the organization.
2.3	**Decision Point Number 'X' (DP 'X')**	A specific stage within a process where a decision must be made, based on predefined criteria, to determine the next course of action.
2.4	**Digital Governance Specialist**	A professional responsible for creating, implementing, and overseeing robust digital governance frameworks and policies. This role ensures the effective management and security of digital assets within the organization.
2.5	**Key Performance Indicator (KPI)**	A measurable value that reflects how well something is performing compared to a set objective.
2.6	**Product Owner**	A professional who leads the development and implementation of an AI use case. They are deeply involved throughout the lifecycle of the AI application, from ideation and design to deployment and monitoring.

2.7	**Responsible, Accountable, Consulted, Informed (RACI)**	A matrix used to define and clarify roles and responsibilities ensuring clear accountability for tasks or decisions.
2.8	**Risk Assessment**	The systematic process of identifying, analyzing, and evaluating risks to determine their potential impact and likelihood, often used for decision-making on risk mitigation.
2.9	**Risk Mitigation**	Actions or strategies implemented to reduce or eliminate the likelihood or impact of identified risks to acceptable levels.
2.10	**Risk Monitoring**	Continuous process of tracking and evaluating known risks, identifying new ones, and assessing the effectiveness of risk mitigation strategies.
2.11	**Risk Register**	A documented log of identified risks, including their severity, likelihood, mitigation measures, and monitoring status, used to track and manage risks throughout a project or system lifecycle.
2.12	**Service Level Agreements (SLA)**	A formal document that outlines the expectations between a service provider and the beneficiary.
2.13	**Use Case (UC)**	A specific situation or scenario where AI technology is applied to solve a problem or improve processes in healthcare, such as treatment recommendations or patient triage.

3.Recommended Protocol

Process:

The process is divided into 4 sections:

1. Risk Assessment
2. Risk Evaluation and Treatment
3. Risk Monitoring and Review
4. Risk Communication & Consultation

Risk Assessment

Step 1: Identification, Classification and Valuation of Assets

The Asset Identification stage is the first phase of risk management in AI. This phase provides a comprehensive understanding of what needs to be protected and managed, laying the foundation for subsequent risk assessment and mitigation actions. Proper asset identification ensures that potential vulnerabilities and threats are evaluated in the context of their importance to the organization.

Assets are not limited to AI systems, but also data assets, platforms, devices, agents, tools and interfaces that support AI systems. The criticality of an asset is subjective to organization needs.

Classification	Description	Impact	Example
Low (1)	Systems that are not directly or indirectly related to treatment of patients.	Errors do not harm patient health and wellbeing.	Spam filters
Medium (2)	Systems that support non-critical functions with minimal impact on patient safety.	Errors do not harm patient health and wellbeing.	Appointment Scheduling System
High (3)	Systems that can influence patient treatment with complete human oversight.	Errors can potentially lead to mistreatment or delayed treatment.	Clinical Decision Support
Very High (4)	Systems that directly interact with patient care.	Errors can lead to serious injury or death.	Surgical Robot

Step 2: Identification and Assessment of Threat and Vulnerabilities

2.1 Identify threats, vulnerabilities and associated risks

Identifying threats and vulnerabilities is a fundamental step towards ensuring the safe and effective deployment of AI systems. This process requires examining various aspects of the AI system, including its architecture, data sources, algorithms, and operational environment. Common threats might include hallucinations, data drift, cyberattacks, data breaches, or malicious actors exploiting system weaknesses. Vulnerabilities often arise from issues such as biased training data, insufficient security measures, or flaws in the model's design. Additionally, unintended behaviors can emerge due to complex interactions within the system or unforeseen environmental conditions.

2.2 Likelihood of occurrence

Identify potential threats and vulnerabilities associated with the assets.
Using historical data, scenario modeling, expert judgment; assess the likelihood of threat occurring.
Likelihood can be calculated in a scale (1-5):

Almost Certain (5)
Likely (4)
Possible (3)
Unlikely (2)
Extremely Unlikely (1)

2.3 Impact evaluation

This step assesses the potential consequences or severity of each identified threat if it were to occur.
Based on historical data, expert judgment, or quantitative analysis, evaluate the potential effects of each threat and assign a severity score. Score can be based on a scale of 1-5

Very high (5)
High (4)
Medium (3)
Low (2)
Very Low (1)

Following is an illustrative categories of impacts but can differ depending on organizations

Safety and Health (5)	Risk to patient safety or user wellbeing.
Privacy and Confidentiality (5)	Exposure of sensitive health data.
Reputation Damage (3-5)	Loss of trust in healthcare providers or AI systems.
Financial Impact (3-5)	Costs associated with errors, legal penalties, or remediation.
Operational Disruptions (1-5)	Downtime or failure of AI services.

Step 3: Risk Calculation

3.1 Exposure Factor

Risk can be defined as the condition in which the threat exploits the existing vulnerability to impact the availability of the asset thereby affecting the business operations. The risk value is arrived based on the product of Likelihood (threat level) and Consequence (impact level):

Exposure Factor = Threat Likelihood X Impact (on threat realization)

Based on the risks that are identified based on the given level of Threat and its impact to the Organization and its business operations, it is vital to rank the risks for arriving at an appropriate risk mitigation option. The risks are ranked based on a 5x5 matrix where relating the consolidated likelihood of threat and impact levels.

Threat Exposure Factor		Impact (Consequence)				
		Very High (5)	High (4)	Medium (3)	Low (2)	Very Low (1)
Likelihood	Almost Certain (5)	25	20	15	10	5
	Likely (4)	20	16	12	8	4
	Possible (3)	15	12	9	6	3
	Unlikely (2)	10	8	6	4	2
	Extremely Unlikely (1)	5	4	3	2	1

Range	Exposure Factor
1-3	Very Low
4-6	Low
7-12	Medium
13-20	High
Above 21	Very High

3.2 Risk Calculation

Risk Rating = Asset Criticality X Exposure Factor

Risk Rating		Exposure Factor				
		Very High (5)	High (4)	Medium (3)	Low (2)	Very Low (1)
Asset Criticality	Very High (4)	25	20	15	10	4
	High (3)	20	16	12	8	3
	Medium (2)	15	12	9	6	2
	Low (1)	10	8	6	4	1

Risk Rating	Risk Interpretation and Treatment Requirements
Very Low	No action required
Low	Risk of this level may or may not be treated, they need to be considered on a case-by-case basis.
Medium	Risk of this level needs to be treated; they need to be considered on a case-by-case basis. Though priority should be given to treat the risks, it depends on the risk owner/management to take the call.
High	Risks of this level need to be treated to manage the situation.
Very High	These risks have a very high or catastrophic impact on DoH/ADPHC and shall be avoided.

Risk Evaluation and Treatment

Step 4: Control Identification

Controls are identified through a systematic process involving review of existing safeguards, gap analysis, and stakeholder consultation. This includes documenting potential technical, procedural, and organizational measures needed to mitigate residual risks, prioritized based on their effectiveness and feasibility. Controls are tested through simulations or pilot studies before full implementation to ensure their effectiveness in reducing risks and ensuring AI system safety and reliability.

Step 5: Residual Risk Calculation

Residual risks are the risks that remain after the application of the treatment options/controls. The Risk Owner shall decide whether the residual risk is acceptable or not. If the residual risk is not acceptable, risk is evaluated to decide whether to Mitigate, Transfer or Avoid. A re-assessment is aimed at reviewing and identifying suitable risk treatment options or additional controls or risk transfer options such as insurance arrangements, etc. to reduce the risk to an acceptable level.

DP1: Residual Risk Rating

Once the risks are identified and valued, they need to be managed effectively based on the residual risk rating and availability of resources:

Avoid: AI systems that pose **Very high residual risk(s)** must be avoided for implementation.

Accept -Accept the risk as per the Risk Appetite (Preferably low and very low) and review them at a later point, considering the financial and non-financial constraints.
While accepting a specific risk, the risk owner or appropriate management team member shall consider the business impact, cost, issues, benefits, resource availability, etc

Mitigate - Implementing additional controls to reduce the occurrence of the threat until the residual risk is at an acceptable level.

Transfer - Transferring the risk to third party or other agencies by mechanisms such as insurance, service contracts, service level agreements.

If risk is very high, proceed to step 6
If risk is High / Medium, proceed to Step 7
If risk is Low / Very Low, proceed to Step 10

Step 6 Avoid High Risk System

If a system is classified as high risk in spite of existing controls, the implementation of such system must be avoided

Step 7 Risk Mitigation

A risk treatment plan outlines the strategic approach (Mitigate / Transfer) and specific actions to address identified risks. The plan details the responsibilities, resources, timelines, and priorities necessary to implement these measures effectively. Additionally, it includes monitoring and review mechanisms to ensure the treatment measures remain effective. Owner is identified for each of the risks/controls based on the ownership of the assets or group of assets and the responsibility for the maintenance of appropriate controls. The owner of the risk will be responsible for the evaluation and treatment of the risk over time.

Risk Monitoring and Reporting

Periodic monitoring and review will ensure that the controls implemented continue to be appropriate and effective and ensure that any changes within the environment have not impacted the control effectiveness. Control monitoring is intended to detect any deterioration in the controls and initiate corrective action.

Step 8: Monitor Treatment Plan

Consistent and systematic evaluation of the treatment plan's progress is vital to ensure the effective execution of mitigation strategies. Regular reviews help identify any obstacles or delays in implementing the measures, allowing for timely adjustments and resource allocation to keep the risk treatment plan on track.

Monitoring the status of the treatment plans also provides assurance that the actions taken are aligned with organizational goals and compliance requirements.

DP2: Successful treatment or risks

If risks are successfully treated, proceed to Step 9
If risks are not successfully treated, revisit the treatment plan in Step 7

Step 9: Update existing controls

Once the treatment plan has been fully executed and all designated measures are in place, these measures serve as controls during risk assessment processes. They help to manage the identified risks, thereby reducing the inherent risk rating and strengthening the trust in the AI system. Continuous monitoring of post-implementation ensures that controls remain effective and adapt to any evolving threats or changes in the environment.

Step 10: Reassessment of Risk and Control effectiveness

10.1 Reassessment of Risk

To ensure that changes in the environment have not affected the originally assessed risks, risk assessment review shall be conducted at planned intervals. The review should be carried out on an ad-hoc basis when significant changes happen in the environment or as defined by the Risk Management Process. The residual risk shall also be assessed for further risk treatment or acceptance.

Risk reviews shall consider the following:

10.1.1 Any changes to the organization after the last risk assessment.

10.1.2 Any changes to the technology after the last risk assessment.

10.1.3 Any changes to the business objective and the processes after the last risk assessment.

10.1.4 Any new threats/vulnerabilities or change in the identified threat/vulnerability value.

10.2 Reassessment of Control Effectiveness

Regular assessments shall be conducted to ensure that controls are implemented and operate effectively. Action shall be taken because of monitoring, review and audits. These actions shall be verified to ensure that they:

Relate to the identified root cause and appropriately address the problem.

Controls have been implemented.

Are effective in preventing recurrence of the problem.

The verification evidence needed might require a repetition of the PDCA (Plan-Do-Check-Act) cycle.

Risk Communication & Consultation

Risk communication and consultation are vital components of an effective AI risk management framework, especially regarding reporting to the Department of Health (DoH). This process involves transparently sharing information about identified risks, ongoing risk mitigation efforts, incidents, and system performance with relevant stakeholders, including the DoH, healthcare providers, patients, and other regulatory bodies. When reporting to the DoH, organizations must ensure that communication is clear, accurate, and timely. This includes providing comprehensive documentation of risk assessments, including the nature of risks identified, the controls implemented, incident reports, and corrective actions taken. Regular reporting may involve submitting risk management reports, audit findings, and updates on the effectiveness of mitigation measures. It is essential to adhere to DoH guidelines and standards for AI system safety and risk reporting, ensuring that all required data and evidence are systematically compiled and presented.

Step 11: Review and Consultation

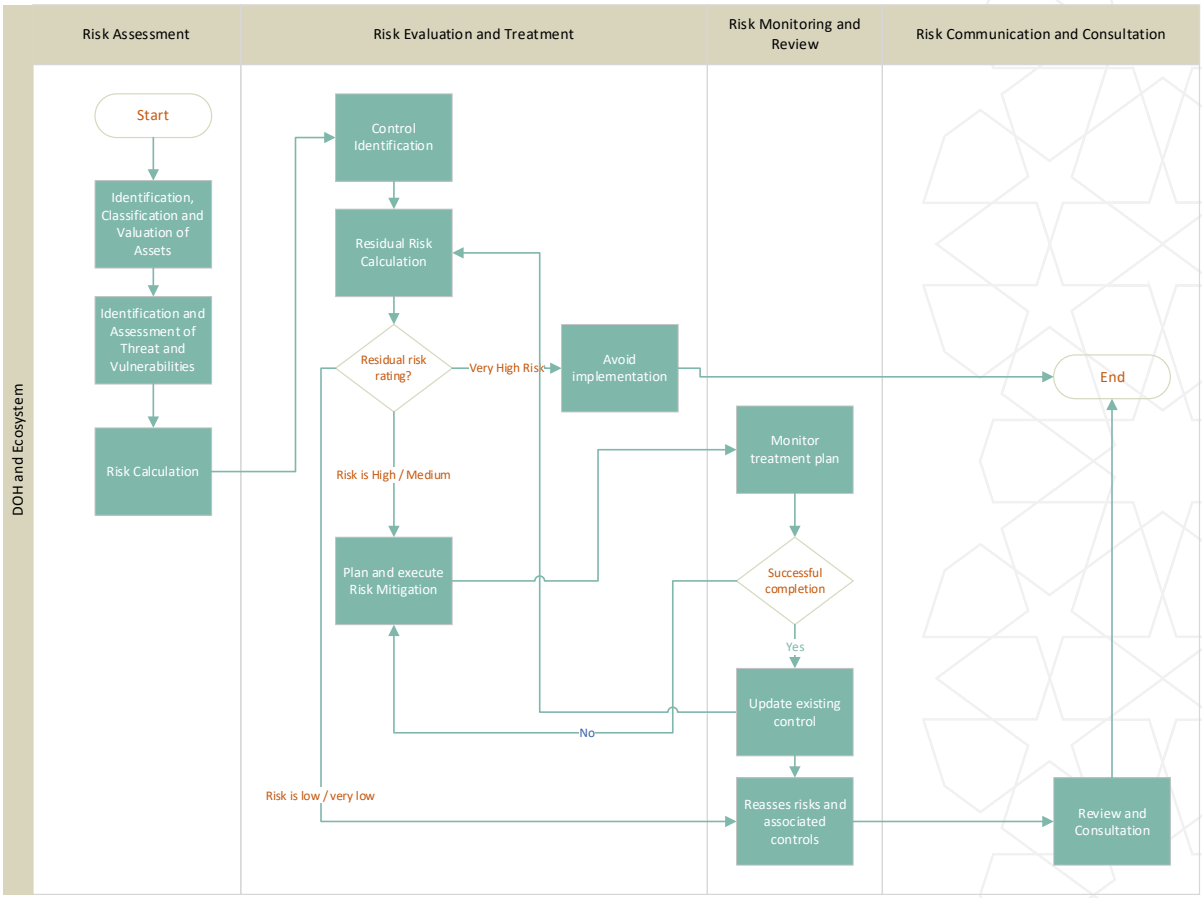
11.1 Review of High-Risk AI systems

Engagement with the DoH also involves consultation to clarify risk-related concerns, seek guidance on complex issues, and align risk management practices with national healthcare policies and regulatory requirements. This may include participating in compliance audits, consultation meetings, or discussions on emerging risks associated with AI systems. Effective risk communication and consultation foster trust, promote transparency, and ensure that the DoH remains informed of potential safety issues, thereby enabling timely regulatory oversight and support. Moreover, open dialogue facilitates continuous improvement of AI governance practices, ensures compliance with legal and ethical standards, and reinforces accountability for patient safety and healthcare quality.

11.2 Review of Risk Register

The review of the risk register by the Department of Health (DoH) is a vital process that ensures all AI-related risks, controls, and mitigation measures are appropriately documented and aligned with regulatory standards. During the review, the DoH assesses the completeness, accuracy, and effectiveness of the risk management strategies outlined in the register. This process helps identify any gaps or areas needing improvement, provides opportunities for the DoH to offer guidance, and ensures that the organization's risk management practices are robust and compliant with national healthcare policies. Regular review by the DoH not only promotes transparency and accountability but also supports continuous improvement in the safety and reliability of AI systems deployed in healthcare, safeguarding patient safety and maintaining public trust.

Process (Illustration):



Service Level Agreement (SLA)

#	Process Step	SLA (Business Days)
1	Identify and evaluate Assets	1
2	Identify Threats and Vulnerabilities	2
3	Identify Risks and Calculate Risk Rating	2
4	Determine Controls	3
5	Calculate Residual Risk	1
6	Avoid High Risk system	-
7	Risk Mitigation	2
8	Monitor treatment plan success	-
9	Monitor risks and associated controls	1
10	Reassessment of Risk and Control effectivess	2
11	Review and Consultation	-

KPI

#	KPI	Description	Calculation	Frequency	Threshold
1	**Percentage of completed treatment plans for risk valued as 'High' & Medium**	This KPI measures the percentage of risk treatment completion for risks valued as 'High' & 'Very High'	Number of completed treatment plans for 'High' & Very High' risks divided by total approved risk treatment plans for 'High' & 'Very High' risks multiplied by 100	Annual	100%
2	**AI Ethical Incident Rate**	Monitors the occurrence of incidents or near misses related to ethical concerns in deployed AI systems, reflecting the overall ethical health of AI applications.	(Number of Ethical Incidents / Total Number of Deployed AI Use Cases) * 100	Annually	< 15%

4.Relevant Reference Documents			
No.	**Reference Date**	**Reference Name**	**Relation Explanation / Coding / Publication Links**
1	July-2025	**DoH AI Policy**	https://www.doh.gov.ae/en/resources/policies
2	July-2025	**DoH AI Standard**	https://www.doh.gov.ae/en/resources/standards